

## CAPÍTULO 6 · RESUMO DE ESTUDO

# Gestão de Riscos e Proteção Contra Ataques

Como a gestão de riscos se integra à governança corporativa, o ciclo completo do Nist RMF e da ISO/IEC 27005 (identificar → analisar → avaliar → tratar → monitorar), os controles que respondem ao tratamento de riscos e a defesa proativa — condensado para revisão antes da prova.

Curso Educação a Distância · Segurança e Auditoria de Sistemas de Informação

Base Nist SP 800-30/37/39/53/61/115/137, Nistir 8286, ABNT NBR ISO 31000/22301, ISO/IEC 27005, Enisa, Cobit 2019, CIS Controls

1. Governança de riscos

2. O ciclo de gestão de riscos

3. Controles como resposta

4–5. Defesa proativa & incidentes

6–7. Frameworks & temas emergentes

Termos-chave

Revisão rápida

01

## Integração entre gestão de riscos e governança corporativa

A gestão de riscos de segurança da informação é a base de toda a proteção cibernética: dela derivam os processos de identificação, análise e mitigação das ameaças à confidencialidade, integridade, privacidade e disponibilidade. Segundo o Nist SP 800-39, ela deve ocorrer de forma **contínua e em múltiplos níveis** — organizacional (estratégico), de missão/processo de negócio (tático) e de sistema de informação (operacional).

O risco de segurança deve ser tratado como **risco corporativo**. A publicação Nistir 8286 propõe a integração entre o **CSRM** (cybersecurity risk management) e o **ERM** (enterprise risk management) —

para que riscos cibernéticos deixem de ser vistos apenas como problemas técnicos e passem a impactar diretamente os objetivos da empresa. A ISO/IEC 27005, alinhada à ISO 31000, reforça que essa gestão deve ser parte da governança organizacional.

### DOIS CONCEITOS CENTRAIS

**Risco residual** — o que permanece após a aplicação dos controles, e que deve ser formalmente aceito pela gestão. **Apetite ao risco** — o nível de risco que a organização está preparada a assumir para alcançar seus objetivos estratégicos.

02

## O ciclo de gestão de riscos: Nist RMF x ISO/IEC 27005

O Nist RMF (SP 800-37r2) mostra "**como aplicar**" a gestão de riscos em nível operacional; a ISO/IEC 27005 define "**como pensar**" o risco em nível organizacional. As duas descrevem, na prática, o mesmo ciclo contínuo.

#### 1 • identificar

##### Ativos, ameaças, vulnerabilidades

Mapeia dependências críticas e interfaces externas (SP 800-30r1).  
Fontes: NVD, CVE Program, Mitre ATT&CK Matrix, relatórios Enisa.

#### 2 • analisar

##### Probabilidade x impacto

Métricas qualitativas, semiquantitativas ou quantitativas (IR 8286A). O modelo Fair estima riscos em valores financeiros.

#### 3 • avaliar

##### Comparar com critérios

Compara a análise com os critérios de aceitação da empresa: risco aceitável, tratável ou a monitorar (IR 8286B).

#### 4 • tratar

##### Selecionar estratégia

Mitigar, evitar, transferir ou aceitar — com base na priorização definida na avaliação (SP 800-37r2, ISO/IEC 27005).

#### 5 • monitorar

##### Acompanhamento contínuo

Avalia permanentemente a eficácia dos controles e identifica novos riscos (SP 800-137/137A), retroalimentando o ciclo.

## Análise de riscos — matriz probabilidade x impacto

Forma comum de visualizar a análise qualitativa: cruzar a probabilidade de ocorrência com o impacto potencial para priorizar o tratamento.



### Tratamento de riscos — as 4 estratégias

#### Mitigar

Aplicar controles técnicos, administrativos, físicos ou jurídicos para reduzir probabilidade ou impacto. É a abordagem mais comum.

#### Evitar

Eliminar a fonte do risco ou interromper a atividade que o gera.

#### Transferir

Compartilhar parte da responsabilidade — por contratos, seguros ou terceirização.

#### Aceitar

Reconhecer o risco e não adotar ações adicionais, quando o residual está dentro do apetite definido.

#### BASELINES E TAILORING

A publicação Nist SP 800-53B define **baselines** — conjuntos de controles de partida conforme o nível de risco. O **tailoring** é o ajuste desses baselines às necessidades específicas da organização (impacto, ambiente operacional, requisitos legais), garantindo controles proporcionais e eficazes.

03

# Controles e políticas de segurança como resposta ao tratamento de riscos

Frameworks e normas — Nist SP 800-53r5, o Anexo A da ISO/IEC 27001, a ISO/IEC 27002 e a ISO/IEC 27005 — fornecem o repertório de controles que traduzem as decisões de tratamento em medidas concretas.

| TIPO DE RISCO                      | CONTROLE CORRESPONDENTE                                               |
|------------------------------------|-----------------------------------------------------------------------|
| Acesso não autorizado              | Controles de autenticação e autorização (ex.: MFA, menor privilégio). |
| Uso indevido de privilégios        | Mecanismos de auditoria e segregação de funções.                      |
| Falhas em mudanças de configuração | Processos formais de gestão de mudanças.                              |

Entre os controles mais relevantes (famílias *access control* e *identification and authentication* do SP 800-53r5): implementar **MFA**, aplicar o **princípio do menor privilégio**, e revisar/registrar acessos privilegiados para garantir rastreabilidade e resposta a incidentes. A Enisa recomenda ainda gestão de contas privilegiadas e revisões periódicas de permissões, especialmente em nuvem e serviços gerenciados.

04-05

# Defesa proativa, testes técnicos e continuidade de negócios

A eficácia da gestão de riscos depende da capacidade de detectar, analisar e responder rapidamente a ameaças em constante evolução.

**Govern** → **Identify** → **Protect** → **Detect** → **Respond** → **Recover**. Funções interdependentes que promovem um ciclo contínuo de prevenção, detecção e aprimoramento das defesas cibernéticas.

**Defesa proativa** combina monitoramento contínuo com **threat intelligence** e **threat hunting** — busca ativa e sistemática por indícios de ataques ou comportamentos anômalos que ainda não foram detectados por ferramentas automatizadas, procurando indicadores de comprometimento (IoCs). Reduz o tempo de permanência do invasor no ambiente.

Como extensão dessa defesa, o Nist SP 800-115 orienta **testes técnicos**: varreduras automatizadas de vulnerabilidades, testes de penetração (pentest) e análises de configuração/conformidade — validando a eficácia real dos controles.

Quando um incidente não pôde ser evitado, o Nist SP 800-61r3 estrutura a resposta em: **preparação, detecção, análise, contenção, erradicação, recuperação e aprendizado**. Essas práticas se conectam à **continuidade de negócios**: a ABNT NBR ISO 22301 exige que os planos de continuidade (BCP) e de recuperação de desastres (DRP) sejam testados periodicamente e integrados ao SGSI.

06-07

## Frameworks complementares e temas emergentes

A consolidação da gestão de riscos é sustentada por frameworks adicionais, e a proteção cibernética precisa evoluir junto com novas tecnologias.

| FRAMEWORK                       | CONTRIBUIÇÃO                                                                                                                             |
|---------------------------------|------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Cobit 2019</b>               | Estrutura de governança para alinhar riscos de TI aos objetivos corporativos.                                                            |
| <b>CIS Controls v8.1</b>        | Controles essenciais priorizados: inventário de ativos, defesa contra malware, proteção de dados.                                        |
| <b>Fair Model</b>               | Mensuração quantitativa de riscos cibernéticos em valores monetários.                                                                    |
| <b>Enisa Technical Guidance</b> | 13 domínios técnicos exigidos pela diretiva europeia NIS2: políticas, incidentes, cadeia de suprimentos, criptografia, segurança física. |

**ASPECTOS EMERGENTES**

**IA generativa (GenAI):** exige governança de modelos e proteção contra vazamento, viés e desinformação.

**OT/ICS:** sistemas industriais exigem segmentação de rede, autenticação robusta e monitoramento contínuo da integridade dos processos (SP 800-82r3).

**Criptografia pós-quântica:** o Nist PQC Project orienta o inventário e a substituição gradual de algoritmos por alternativas resistentes a computadores quânticos.



## Termos-chave

Vocabulário que costuma aparecer em questões de múltipla escolha.

**CSRM**

Cybersecurity risk management — gestão de riscos cibernéticos.

**RMF**

Risk management framework (Nist SP 800-37r2) — ciclo operacional de gestão de riscos.

**Apetite ao risco**

Nível de risco que a organização está disposta a assumir para atingir seus objetivos.

**Baseline de segurança**

Conjunto de controles de partida definido conforme o nível de risco (SP 800-53B).

**Threat hunting**

Busca ativa por indícios de ataques ainda não detectados por ferramentas automatizadas.

**BCP / DRP****ERM**

Enterprise risk management — gestão de riscos corporativos.

**Risco residual**

O que permanece após a aplicação dos controles; exige aceitação formal da gestão.

**Tolerância ao risco**

Limites máximos aceitáveis antes de exigir ações corretivas.

**Tailoring**

Ajuste de um baseline às necessidades específicas da organização.

**IoC**

Indicator of compromise — indicador de comprometimento.

**Fair**

Plano de continuidade de negócios / plano de recuperação de desastres.

Factor analysis of information risk — modelo quantitativo de risco em valores monetários.



## Revisão rápida antes da prova

Confira se você consegue responder a cada ponto sem consultar o texto.

- ☐ Explicar por que o risco de segurança deve ser tratado como risco corporativo (CSRM + ERM).
- ☐ Diferenciar risco residual de apetite ao risco.
- ☐ Explicar a diferença entre o Nist RMF ("como aplicar") e a ISO/IEC 27005 ("como pensar").
- ☐ Listar as 5 etapas do ciclo de gestão de riscos: identificar, analisar, avaliar, tratar, monitorar.
- ☐ Diferenciar as 4 estratégias de tratamento: mitigar, evitar, transferir e aceitar — com um exemplo de cada.
- ☐ Explicar o que é um baseline de segurança e o que significa fazer tailoring dele.
- ☐ Listar as 6 funções do Nist CSF 2.0 (govern, identify, protect, detect, respond, recover).
- ☐ Diferenciar threat hunting de monitoramento automatizado tradicional.
- ☐ Descrever as etapas de resposta a incidentes segundo o Nist SP 800-61r3.
- ☐ Explicar a relação entre gestão de riscos e continuidade de negócios (BCP/DRP, ISO 22301).



## Referências do capítulo

**ABNT.** NBR ISO 31000:2018; NBR ISO/IEC 27001/27002/27005; NBR ISO 22301:2024.

**CIS.** CIS Controls v8.1, 2024.

**Enisa.** Threat landscape 2025; NIS2 technical implementation guidance, 2025.

**Fair Institute.** Factor analysis of information risk (Fair) model, 2022.

**Isaca.** Cobit 2019 Framework, 2019.

**Mitre Corporation.** ATT&CK Matrix for Enterprise; CVE Program, 2025.

**Nist.** SP 800-30r1 (avaliação de riscos); SP 800-37r2 (RMF); SP 800-39 (gestão de riscos); SP 800-53/53B (controles/baselines); SP 800-61r3 (resposta a incidentes); SP 800-82r3 (OT); SP 800-115 (testes técnicos); SP 800-137/137A (monitoramento contínuo); Nistir 8286/8286A/8286B (CSRM x ERM); CSF 2.0; PQC Project (criptografia pós-quântica).

---

Resumo gerado a partir do capítulo "Gestão de riscos e proteção contra ataques" (SEG\_AUD\_SIS\_06\_ACE\_2025) para revisão de prova.